

Botium Toys - Projet de Sécurité Informatique

Documentation Complète du Cas Pratique

Google Cybersecurity Professional Certificate

Table des Matières

1. Contexte du Projet
 2. Périmètre et Objectifs de l'Audit
 3. Inventaire des Actifs
 4. Cadre Méthodologique
 5. Évaluation des Risques
 6. Classification des Contrôles
 7. Checklist des Contrôles
 8. Checklist de Conformité
 9. Recommandations Stratégiques
 10. Plan de Mise en Œuvre
 11. Métriques et Suivi
 12. Conclusion
 13. Annexes
-

1. Contexte du Projet

1.1 Présentation Générale

Ce projet est réalisé dans le cadre de la formation Google Cybersecurity Professional Certificate.

Il s'agit d'un cas pratique basé sur une entreprise fictive : **Botium Toys**.

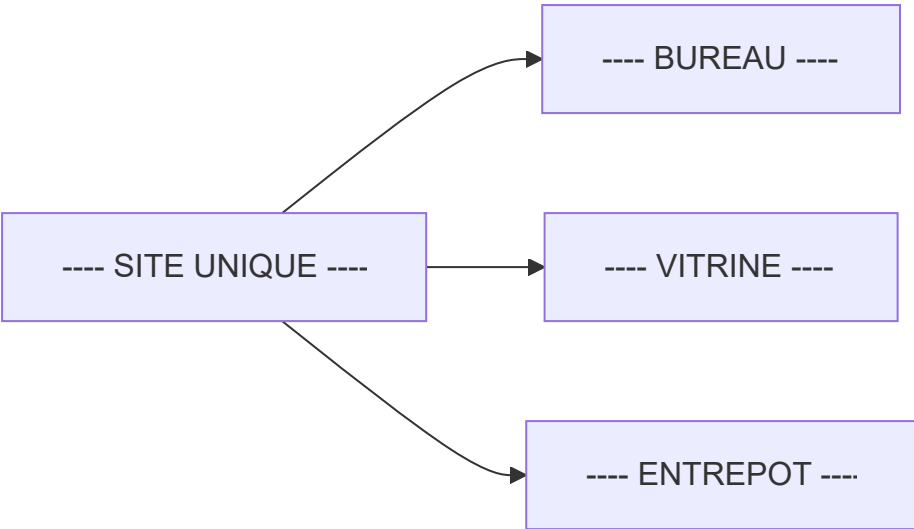
1.2 Description de l'Entreprise

Caractéristique	Détail
Nom	Botium Toys
Secteur	Jouets / Commerce de détail
Taille	Petite entreprise (PME)

Caractéristique	Détail
Localisation	États-Unis (un site physique unique)
Activité	Développement et vente de jouets

1.3 Infrastructure de l'Entreprise

Botium Toys possède un **site physique unique** qui regroupe trois fonctions :



1.4 Expansion et Défis Actuels

Évolution de l'activité :

- 📈 Développement de la présence en ligne
- 🌐 Attraction de clients internationaux (dont Union Européenne)
- 💻 Pression accrue sur le serveur d'authentification
- 🛡️ Augmentation des enjeux de sécurité

1.5 Déclencheur de l'Audit

La responsable du département IT a initié cet audit interne pour plusieurs raisons :

Raison	Détail
Croissance	L'entreprise se développe sans plan de sécurité formalisé
Conformité	Risque de non-conformité avec les réglementations (PCI DSS, GDPR)
Sécurité	Vulnérabilités potentielles des actifs critiques
International	Obligations légales vis-à-vis des clients européens

1.6 Objectifs de l'Audit selon la Responsable IT

1. **Sécuriser** l'infrastructure de l'entreprise

- 2. **Identifier** les risques, menaces ou vulnérabilités
- 3. **Assurer** la conformité réglementaire
- 4. **Anticiper** les impacts de la croissance
- 5. **Protéger** les données des clients (PII/SPII)

1.7 Approche Méthodologique

L'audit s'appuie sur le **NIST CSF** (Cybersecurity Framework) :

NIST CSF - 5 Fonctions				
IDENTIFY (Phase actuelle)	PROTECT	DETECT	RESPOND	RECOVER

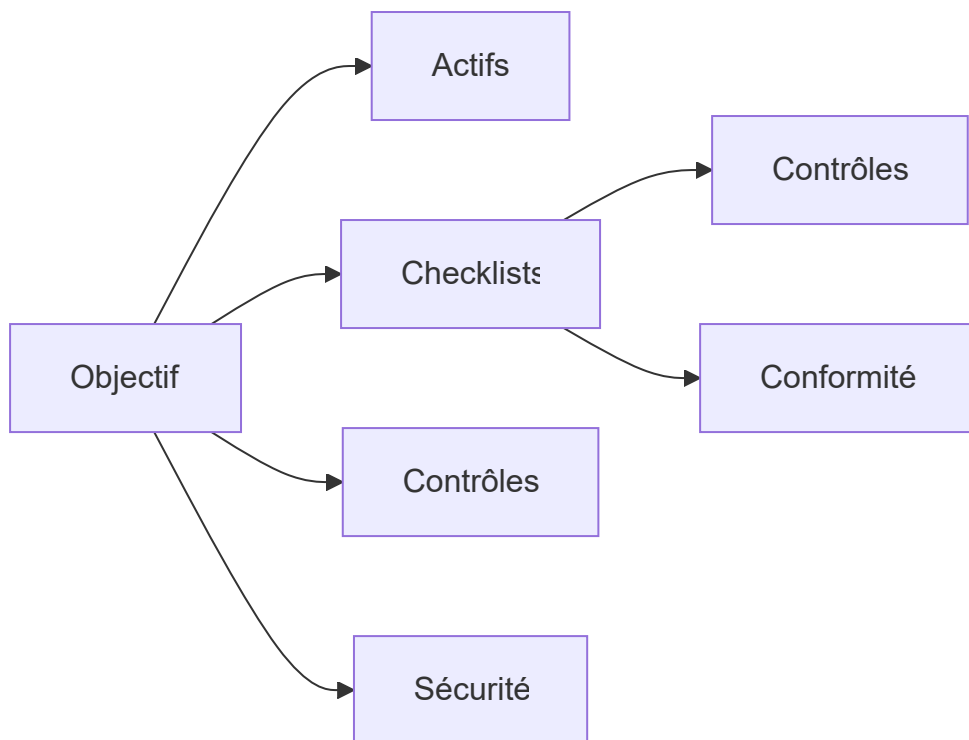
2. Périmètre et Objectifs de l'Audit

2.1 Périmètre Défini

Le périmètre de l'audit couvre :

Domaine	Éléments Inclus
Programme de sécurité	L'intégralité du programme de sécurité de Botium Toys
Actifs	Tous les actifs gérés par le département IT
Processus	Procédures internes et mise en œuvre des contrôles
Conformité	Pratiques de conformité réglementaire

2.2 Objectifs Spécifiques



2.3 Résultats Attendus

1. **Vue d'ensemble** des risques et des amendes potentielles
 2. **État des lieux** des contrôles existants
 3. **Diagnostic** de conformité
 4. **Recommandations** hiérarchisées
 5. **Plan d'action** pour l'amélioration de la sécurité
-

3. Inventaire des Actifs

3.1 Actifs Gérés par le Département IT

3.1.1 Équipements Physiques (On-Premises)

- 🏢 Équipements de Bureau
 - ├─ Postes de travail (ordinateurs de bureau)
 - ├─ Ordinateurs portables
 - ├─ Smartphones
 - ├─ Postes de télétravail
 - ├─ Périphériques
 - ├─ Casques audio
 - ├─ Câbles
 - ├─ Claviers
 - ├─ Souris
 - └─ Stations d'accueil
 - └─ Caméras de surveillance

3.1.2 Actifs Commerciaux

-  Actifs Commerciaux
 - └ Produits en magasin (vente sur site)
 - └ Produits en ligne (e-commerce)
 - └ Stock en entrepôt (situé sur le même site)

3.1.3 Systèmes, Logiciels et Services

-  Systèmes et Logiciels
 - └ Système comptable
 - └ Télécommunications
 - └ Gestion de bases de données
 - └ Sécurité
 - └ Commerce électronique
 - └ Gestion des stocks

3.1.4 Infrastructure Réseau

-  Infrastructure Réseau
 - └ Accès Internet
 - └ Réseau interne
 - └ Système de stockage et rétention des données

3.1.5 Systèmes Hérités (Legacy)

-  Systèmes Hérités
 - └ Systèmes en fin de vie
 - └ Nécessitent une surveillance humaine

3.2 Synthèse des Actifs

Catégorie	Nombre	Criticité
Équipements physiques	Multiple	Élevée
Actifs commerciaux	Stock variable	Élevée
Systèmes et logiciels	6+ systèmes	Critique
Infrastructure réseau	3 composants	Critique
Systèmes hérités	Variable	Moyenne

4. Cadre Méthodologique

4.1 NIST CSF - Framework Utilisé

L'audit suit le **Cybersecurity Framework (CSF)** du NIST :

Fonction	Description	Application
Identify	Identifier les actifs et les risques	Phase 1 de l'audit
Protect	Mettre en place des sauvegardes	Recommandations
Detect	Détecter les événements	Recommandations
Respond	Répondre aux incidents	Plan d'action
Recover	Rétablir les capacités	Plan d'action

4.2 Processus d'Audit

- Phase 1: Définition
 - └ Périimètre et objectifs
 - └ Inventaire des actifs
 - └ Évaluation des risques
- Phase 2: Analyse
 - └ Classification des contrôles
 - └ Checklist des contrôles
 - └ Checklist de conformité
- Phase 3: Recommandations
 - └ Hiérarchisation
 - └ Plan d'action
 - └ Métriques de suivi

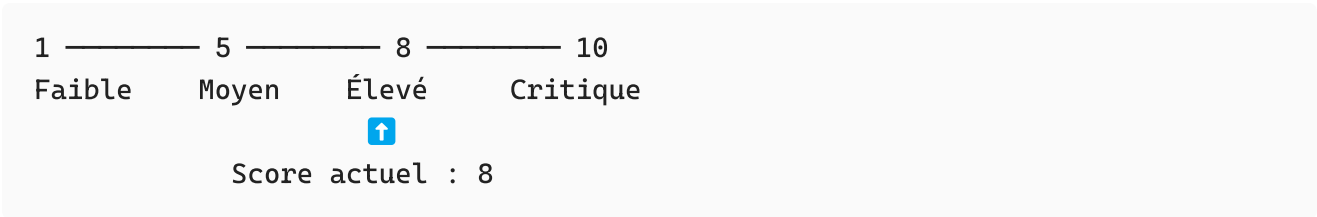
4.3 Référentiels de Conformité

Référentiel	Domaine d'application
PCI DSS	Sécurité des transactions par carte bancaire
GDPR	Protection des données des clients européens
SOC 1 & 2	Contrôles des systèmes et organisations

5. Évaluation des Risques

5.1 Méthodologie d'Évaluation

Échelle de risque : 1 à 10



5.2 Description des Risques

5.2.1 Risque Global

"Risque élevé (8/10) dû à un manque de contrôles et d'adhésion aux pratiques de conformité."

5.2.2 Détails des Vulnérabilités

#	Vulnérabilité	Impact	Priorité
1	Accès généralisé aux données	Accès non autorisé aux PII/SPII	Critique
2	Absence de chiffrement	Données bancaires non protégées	Critique
3	Absence de moindre privilège	Risque d'actions malveillantes	Élevée
4	Absence de séparation des tâches	Risque de fraude interne	Élevée
5	Absence d'IDS	Détection des intrusions impossible	Élevée
6	Absence de DRP	Pas de continuité d'activité	Élevée
7	Absence de sauvegardes	Perte de données critiques	Élevée
8	Politique de mots de passe faible	Risque de compromission de comptes	Élevée

5.3 Analyse des Risques par Domaine

5.3.1 Gestion des Accès

État actuel : ● CRITIQUE

└─ Tous les employés ont accès à toutes les données

└─ Données internes

└─ Données de cartes de crédit

└─ PII/SPII des clients

Risques :

└─ Fuite de données

- └─ Usage non autorisé
- └─ Non-conformité PCI DSS/GDPR

5.3.2 Sécurité des Données

État actuel : ● CRITIQUE

- └─ Aucun chiffrement des données
 - └─ Données en transit non protégées
 - └─ Données au repos non sécurisées

Risques :

- └─ Interception des transactions
- └─ Vol de données sensibles
- └─ Sanctions financières

5.3.3 Sécurité Réseau

État actuel : ● PARTIEL

- └─ ✓ Pare-feu présent
- └─ ✗ Aucun IDS

Risques :

- └─ Attaques non détectées
- └─ Intrusions silencieuses
- └─ Temps de réponse retardé

5.3.4 Continuité d'Activité

État actuel : ● CRITIQUE

- └─ ✗ Pas de DRP
- └─ ✗ Pas de sauvegardes

Risques :

- └─ Arrêt des opérations
- └─ Perte définitive de données
- └─ Rupture de la chaîne de valeur

5.3.5 Sécurité Physique

État actuel : ● BON

- └─ ✓ Serrures suffisantes
- └─ ✓ CCTV à jour
- └─ ✓ Détection incendie

Risques : Faibles

5.4 Matrice des Risques

	Faible Impact	Impact Moyen	Impact Élevé
Faible Probabilité	Risque Mineur	Risque Modéré	Risque Important
Probabilité Moyenne	Risque Modéré	Risque Important	⚠ Risque Critique
Probabilité Élevée	Risque Important	⚠ Risque Critique	⚠ Risque Critique

5.5 Synthèse des Risques

Niveau de Risque	Nombre	Actions
Critique	5	Action IMMÉDIATE
Élevé	4	Action URGENTE
Moyen	2	Planifier
Faible	1	Surveiller

6. Classification des Contrôles

6.1 Définition des Catégories de Contrôles

6.1.1 Contrôles Administratifs/Manageriaux



Définition

- └ Adressent le facteur humain de la cybersécurité
 - └ Politiques et procédures
 - └ Définition des responsabilités
 - └ Gestion des données

6.1.2 Contrôles Techniques



Définition

- └ Solutions technologiques
 - └ Pare-feu, IDS/IPS
 - └ Antivirus, Chiffrement
- └ Solutions logicielles

6.1.3 Contrôles Physiques/Opérationnels



Définition

- └ Limiter l'accès physique

- └ Serrures, coffres-forts
- └ Caméras de surveillance
- └ Badges, lecteurs

6.2 Types de Contrôles

Type	Objectif	Exemple
Préventif	Empêcher un incident	Pare-feu, politique de mots de passe
Détectif	Détecter un incident en cours	IDS, CCTV
Correctif	Restaurer après incident	Sauvegardes, DRP
Dissuasif	Décourager les attaques	Chiffrement, signalétique

6.3 Détail des Contrôles

6.3.1 Contrôles Administratifs/Manageriaux

Contrôle	Type	Objectif
Moindre Privilège	Préventif	Réduire l'impact des comptes compromis
Plans de Reprise (DRP)	Correctif	Assurer la continuité d'activité
Politiques de Mots de Passe	Préventif	Réduire les risques de compromission
Politiques de Contrôle d'Accès	Préventif	Définir les groupes d'accès
Gestion des Comptes	Préventif	Gérer le cycle de vie des comptes
Séparation des Tâches	Préventif	Réduire les risques d'actions malveillantes

6.3.2 Contrôles Techniques

Contrôle	Type	Objectif
Pare-feu	Préventif	Filtrer le trafic malveillant
IDS/IPS	Détectif	Détecter les anomalies réseau
Chiffrement	Dissuasif	Assurer la confidentialité
Sauvegardes	Correctif	Restaurer après incident
Gestion des Mots de Passe	Préventif	Réduire la fatigue des mots de passe
Antivirus	Correctif	Détecter et mettre en quarantaine
Maintenance Manuelle	Préventif	Gérer les systèmes obsolètes

6.3.3 Contrôles Physiques/Opérationnels

Contrôle	Type	Objectif
Coffre temporisé	Dissuasif	Sécuriser les actifs physiques
Éclairage adéquat	Dissuasif	Limiter les cachettes
CCTV	Préventif/Détectif	Surveillance et preuves
Armoires verrouillées	Préventif	Protéger l'infrastructure réseau
Signalétique	Dissuasif	Dissuader les attaques
Serrures	Dissuasif/Préventif	Contrôle d'accès physique
Détection Incendie	Détectif/Préventif	Protection des actifs

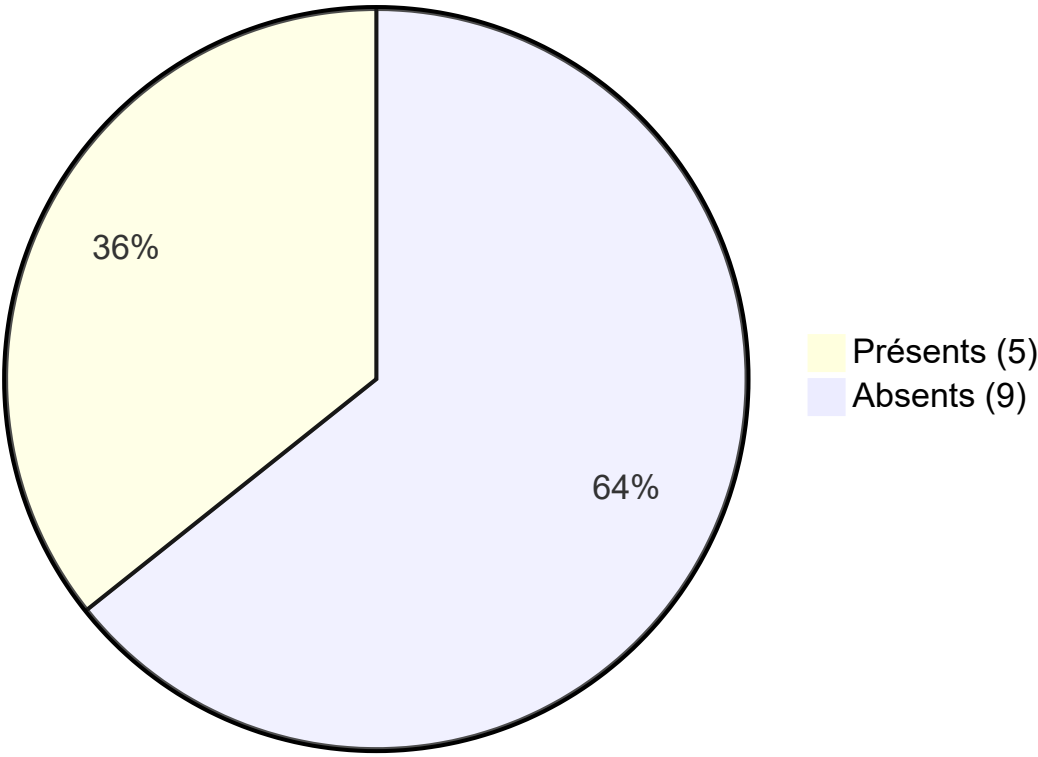
7. Checklist des Contrôles

7.1 État Actuel des Contrôles

#	Contrôle	Statut	Type	Priorité
1	Moindre Privilège	✗ NON	Administratif	● Critique
2	Plans de Reprise (DRP)	✗ NON	Administratif	● Critique
3	Politiques de Mots de Passe	✗ NON	Administratif	● Critique
4	Séparation des Tâches	✗ NON	Administratif	● Critique
5	Pare-feu	✓ OUI	Technique	✓ OK
6	Intrusion Detection System (IDS)	✗ NON	Technique	● Critique
7	Sauvegardes	✗ NON	Technique	● Critique
8	Antivirus	✓ OUI	Technique	✓ OK
9	Maintenance Legacy	✓ OUI	Technique	● Moyenne
10	Chiffrement	✗ NON	Technique	● Critique
11	Gestion des Mots de Passe	✗ NON	Technique	● Critique
12	Serrures	✓ OUI	Physique	✓ OK
13	CCTV	✓ OUI	Physique	✓ OK
14	Détection Incendie	✓ OUI	Physique	✓ OK

7.2 Synthèse des Contrôles

Répartition des Contrôles



7.3 Résumé par Catégorie

Catégorie	Présents	Absents	Taux de Couverture
Administratifs	0	4	0%
Techniques	3	4	43%
Physiques	3	0	100%
TOTAL	6	8	43%

8. Checklist de Conformité

8.1 PCI DSS (Payment Card Industry Data Security Standard)

8.1.1 Contexte

Botium Toys accepte, traite, transmet et stocke des données de cartes de crédit.

8.1.2 État de Conformité

#	Best Practice	Statut	Impact
1	Accès limité aux données de cartes de crédit	✗ NON	● Sanctions

#	Best Practice	Statut	Impact
2	Environnement sécurisé pour les transactions	✗ NON	● Sanctions
3	Chiffrement des données de cartes de crédit	✗ NON	● Sanctions
4	Gestion sécurisée des mots de passe	✗ NON	● Sanctions

8.1.3 Évaluation PCI DSS

Statut : NON CONFORME

Risque : CRITIQUE

- └─ Tous les employés peuvent accéder aux données de cartes
- └─ Aucun chiffrement en place
- └─ Absence de contrôle d'accès

Conséquences potentielles :

- └─ Amendes financières
- └─ Perte de la capacité à accepter les cartes
- └─ Dommages à la réputation

8.2 GDPR (General Data Protection Regulation)

8.2.1 Contexte

Botium Toys a des clients dans l'Union Européenne.

8.2.2 État de Conformité

#	Best Practice	Statut	Impact
1	Protection des données clients UE	✗ NON	● Sanctions
2	Notification de brèche en 72h	✓ OUI	✓ OK
3	Classification des données	✗ NON	● Risque
4	Politiques de confidentialité	✓ OUI	✓ OK

8.2.3 Évaluation GDPR

Statut : PARTIELLEMENT CONFORME

Risque : ÉLEVÉ

- └─ Politiques de confidentialité en place ✓
- └─ Procédure de notification 72h en place ✓
- └─ Absence de classification des données ✗

Conséquences potentielles :

- └─ Amendes pouvant atteindre 4% du CA mondial
- └─ Restrictions de traitement des données UE

8.3 SOC (System and Organizations Controls)

8.3.1 Contexte

Botium Toys doit démontrer des contrôles de sécurité robustes.

8.3.2 État de Conformité

#	Best Practice	Statut	Impact
1	Politiques d'accès utilisateur	✗ NON	● Audit
2	Confidentialité des PII/SPII	✗ NON	● Audit
3	Intégrité des données	✗ NON	● Audit
4	Disponibilité des données	✗ NON	● Audit

8.3.3 Évaluation SOC

Statut : NON CONFORME

Risque : ÉLEVÉ

- └─ Aucune politique d'accès formalisée
- └─ Données sensibles non protégées
- └─ Absence de garanties d'intégrité/disponibilité

Conséquences potentielles :

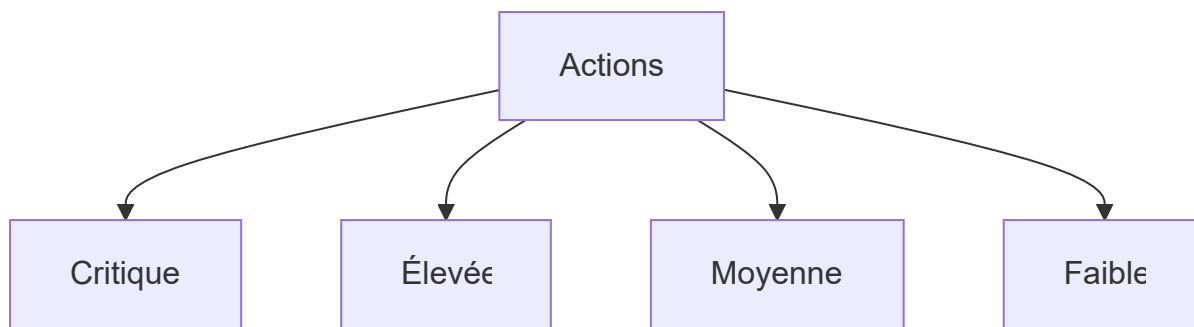
- └─ Échec des audits
- └─ Perte de confiance des partenaires
- └─ Difficultés à établir des contrats B2B

8.4 Synthèse de la Conformité

Référentiel	Statut	Risque	Actions Prioritaires
PCI DSS	NON CONFORME	● Critique	Chiffrement + Contrôle d'accès
GDPR	PARTIELLEMENT	● Élevé	Classification des données
SOC	NON CONFORME	● Élevé	Politiques d'accès + Sécurité

9. Recommandations Stratégiques

9.1 Hiérarchisation des Actions



9.2 Recommandations par Priorité

● PRIORITÉ CRITIQUE (Actions Immédiates)

#	Action	Détails	Impact
1	Chiffrement des données	Données au repos et en transit	Sécurise les transactions
2	Contrôle d'accès PCI DSS	Restreindre l'accès aux données de cartes	Conformité PCI DSS
3	Moindre Privilège	Implémenter le principe du moindre privilège	Réduire les risques internes
4	Séparation des Tâches	Séparer les responsabilités	Prévenir la fraude
5	Système de Détection (IDS)	Déployer un IDS	Détecter les intrusions

● PRIORITÉ ÉLEVÉE (Actions Urgentes)

#	Action	Détails	Impact
6	Politique de Mots de Passe	Renforcer et formaliser	Réduire les compromissions
7	Gestionnaire de Mots de Passe	Déployer un système centralisé	Améliorer la productivité
8	Plan de Reprise (DRP)	Élaborer un DRP	Assurer la continuité
9	Sauvegardes	Mettre en place des sauvegardes	Protéger les données

● PRIORITÉ MOYENNE (Planifier)

#	Action	Détails	Impact
10	Classification des Données	Inventorier et classer	Conformité GDPR/SOC

#	Action	Détails	Impact
11	Maintenance Legacy	Formaliser le planning	Sécuriser les systèmes
12	Formation du Personnel	Sensibiliser à la sécurité	Réduire les erreurs humaines

● PRIORITÉ FAIBLE (Surveiller)

#	Action	Détails	Impact
13	Audits Réguliers	Planifier des audits	Maintenir la conformité
14	Veille Sécurité	Mettre en place une veille	Anticiper les menaces

9.3 Plan d'Action Détaillé

9.3.1 Protection des Données Bancaires (PCI DSS)

Objectif : Mise en conformité PCI DSS
Urgence : CRITIQUE

- Actions :
- Déployer le chiffrement SSL/TLS pour toutes les transactions
 - Mettre en place un environnement sécurisé pour le traitement
 - Implémenter une segmentation réseau pour isoler les données sensibles
 - Configurer des pare-feu dédiés pour le système de paiement

Échéance : 30 jours
Responsable : IT Manager
Budget : Moyen

9.3.2 Gestion des Accès et Identités (IAM)

Objectif : Contrôler les accès aux données
Urgence : CRITIQUE

- Actions :
- Réviser tous les comptes utilisateurs
 - Implémenter le principe du moindre privilège
 - Mettre en place la séparation des tâches
 - Déployer un système IAM centralisé
 - Configurer une authentification multi-facteurs (MFA)

Échéance : 45 jours
Responsable : IT Manager
Budget : Élevé

9.3.3 Sécurité Réseau

Objectif : Protéger le réseau contre les intrusions

Urgence : ÉLEVÉE

Actions :

1. Déployer un système IDS/IPS
2. Mettre à jour et durcir le pare-feu existant
3. Mettre en place des journaux d'audit réseau
4. Segmenter le réseau (DMZ pour l'e-commerce)

Échéance : 60 jours

Responsable : Network Administrator

Budget : Moyen

9.3.4 Continuité d'Activité

Objectif : Assurer la continuité des opérations

Urgence : ÉLEVÉE

Actions :

1. Élaborer un plan de reprise d'activité (DRP)
2. Mettre en place un système de sauvegarde automatisé
3. Tester régulièrement les sauvegardes
4. Documenter les procédures d'urgence

Échéance : 90 jours

Responsable : IT Manager

Budget : Moyen

9.3.5 Sécurité des Mots de Passe

Objectif : Renforcer la politique de mots de passe

Urgence : ÉLEVÉE

Actions :

1. Mettre à jour la politique de mots de passe
 - Minimum 12 caractères
 - Combinaison de caractères
 - Pas de mots courants
2. Déployer un gestionnaire de mots de passe centralisé
3. Imposer un changement régulier des mots de passe
4. Mettre en place une MFA

Échéance : 30 jours

Responsable : Security Analyst
Budget : Faible

10. Plan de Mise en Œuvre

10.1 Calendrier Global

2026 - Août

Sem 1	Sem 2	Sem 3	Sem 4	Sem 5	Sem 6
Phase 1	Phase 1	Phase 2	Phase 2	Phase 3	Phase 3

2026 - Septembre

Sem 1	Sem 2	Sem 3	Sem 4	
Phase 3	Phase 4	Phase 4	Phase 5	

10.2 Phases Détaillées

Phase 1 : Urgence (Semaines 1-3)

Action	Délai	Status
Chiffrement des données	Sem 1-2	En attente
Sécurisation paiements PCI	Sem 1-3	En attente
Politique de mots de passe	Sem 2-3	En attente

Phase 2 : Accès et Identités (Semaines 4-6)

Action	Délai	Status
Implémentation moindre privilège	Sem 4-5	En attente
Mise en place séparation des tâches	Sem 4-5	En attente
Gestionnaire de mots de passe	Sem 5-6	En attente

Phase 3 : Réseau et Sécurité (Semaines 7-10)

Action	Délai	Status
Déploiement IDS	Sem 7-8	En attente
Durcissement pare-feu	Sem 7-8	En attente
Segmentation réseau	Sem 8-10	En attente

Phase 4 : Continuité (Semaines 11-14)

Action	Délai	Status
Élaboration DRP	Sem 11-12	En attente
Mise en place sauvegardes	Sem 12-14	En attente

Phase 5 : Conformité (Semaines 13-16)

Action	Délai	Status
Classification des données	Sem 13-14	En attente
Documentation conformité	Sem 14-16	En attente

10.3 Ressources Nécessaires

10.3.1 Ressources Humaines

Rôle	Compétences	Intervention
IT Manager	Pilotage projet	Permanent
Security Analyst	Sécurité, conformité	Permanent
Network Administrator	Réseau, firewall, IDS	Phase 1-3
System Administrator	Sauvegardes, systèmes	Phase 2-4
External Consultant	Audit, conformité	Ponctuel

10.3.2 Ressources Techniques

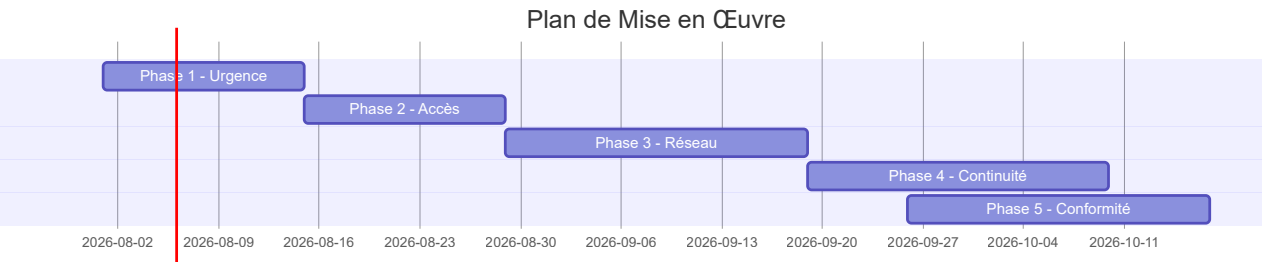
Catégorie	Équipement/Logiciel	Budget Estimé
Sécurité	IDS/IPS, Firewall NG	15 000 €
Infrastructure	Serveurs de sauvegarde	10 000 €
Logiciels	Gestionnaire de mots de passe	5 000 €
Formation	Formation du personnel	3 000 €

Catégorie	Équipement/Logiciel	Budget Estimé
Externalisation	Consultant sécurité	10 000 €
TOTAL		43 000 €

10.3.3 Ressources Formatives

Public	Type de Formation	Durée
Tous les employés	Sensibilisation à la sécurité	2 heures
IT Team	Sécurité réseau et IDS	2 jours
Managers	Conformité et gouvernance	1 jour

10.4 Chronogramme de Suivi



11. Métriques et Suivi

11.1 Indicateurs de Performance (KPIs)

11.1.1 Métriques de Sécurité

KPI	Cible	Méthode de Mesure	Fréquence
Taux de couverture des contrôles	>80%	Checklist	Mensuel
Nombre d'incidents de sécurité	0	Journalisation	Mensuel
Temps moyen de détection (MTTD)	<1h	Analyse des logs	Mensuel
Temps moyen de réponse (MTTR)	<4h	Analyse des logs	Mensuel
Taux de conformité des mots de passe	100%	Audit des comptes	Mensuel
Pourcentage de données chiffrées	100		